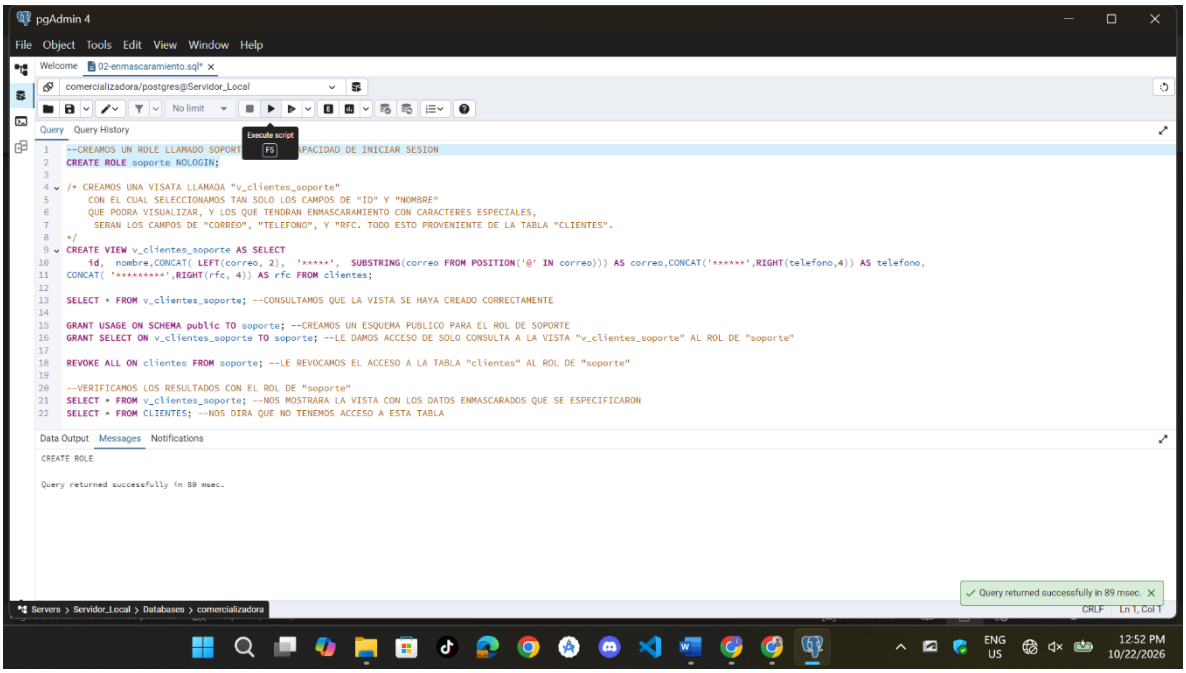
Enmascaramiento (masking)

El área de soporte necesita consultar información de los clientes, pero no requiere visualizar los valores completos de correo, teléfono y RFC.
El objetivo es proporcionar una vista con información parcialmente ocultada y evitar que el usuario tenga acceso directo a la tabla original.

8.1 Crear el rol

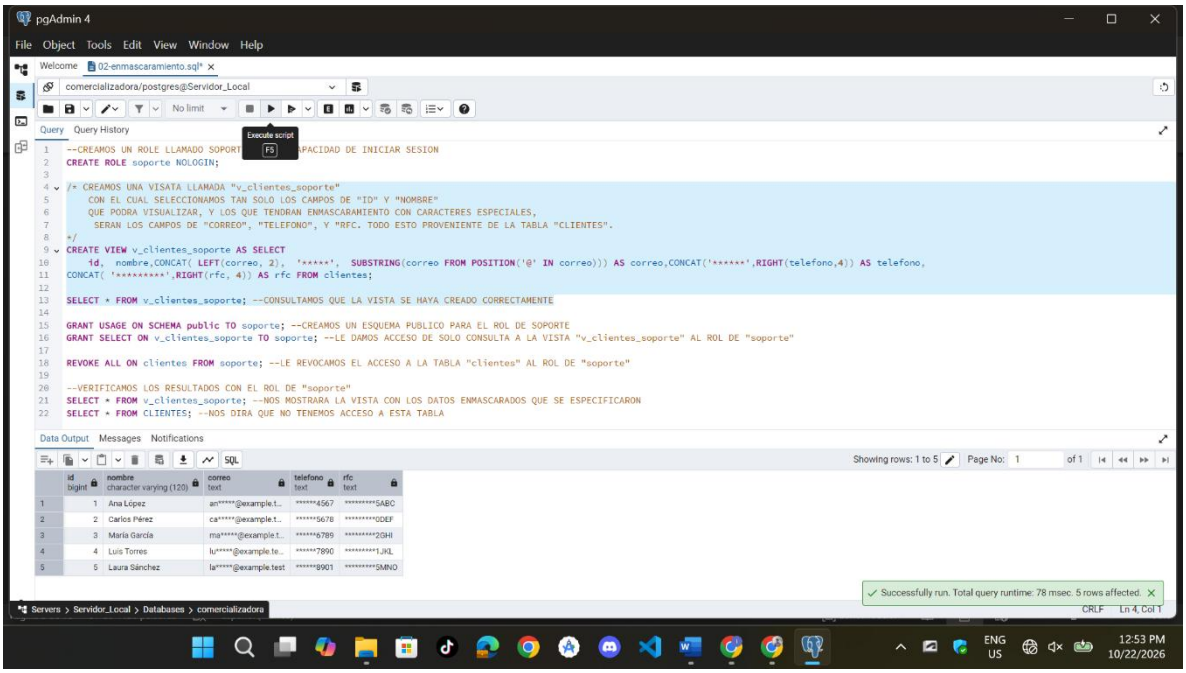
CREATE ROLE soporte NOLOGIN;



8.2 Crear una vista de acceso restringido

CREATE VIEW v_clientes_soporte AS SELECT
id, nombre,CONCAT(LEFT(correo, 2), '*****', SUBSTRING(correo FROM POSITION('@' IN correo))) AS correo,CONCAT('******',RIGHT(telefono,4)) AS telefono,
CONCAT('*********',RIGHT(rfc, 4)) AS rfc FROM clientes;

Consultar la vista:
SELECT * FROM v_clientes_soporte;



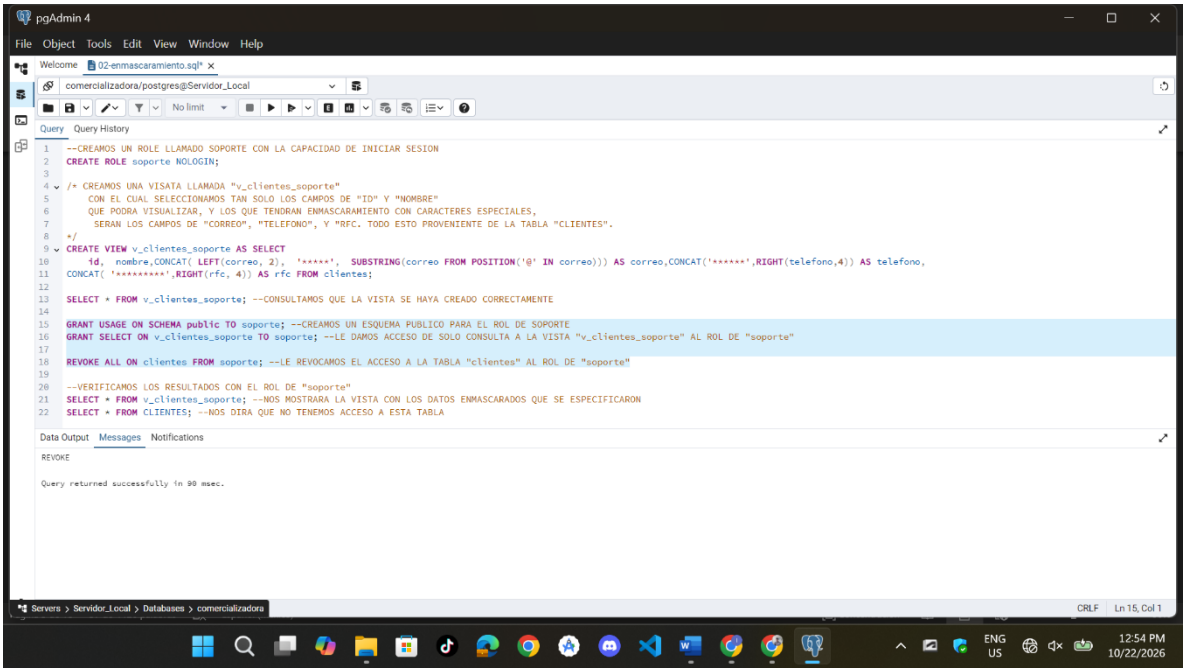
8.3 Conceder acceso a la vista

GRANT USAGE ON SCHEMA public TO soporte;

GRANT SELECT ON v_clientes_soporte TO soporte;

Revocar el acceso directo a la tabla:

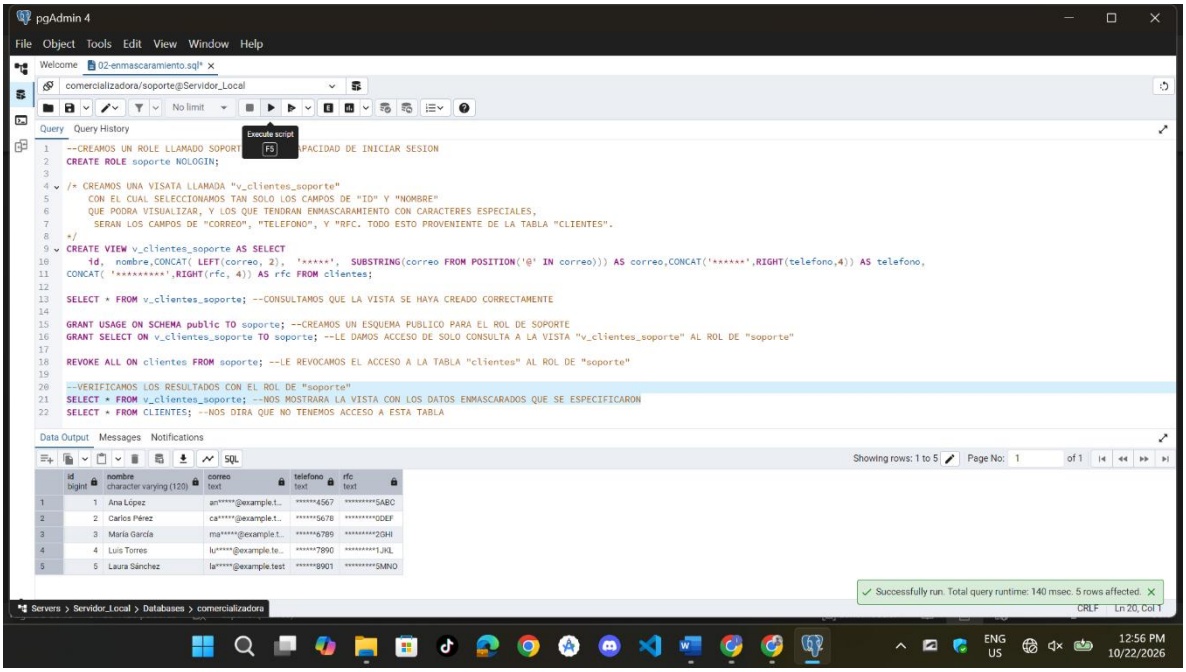
REVOKE ALL ON clientes FROM soporte;



8.4 Verificar el resultado

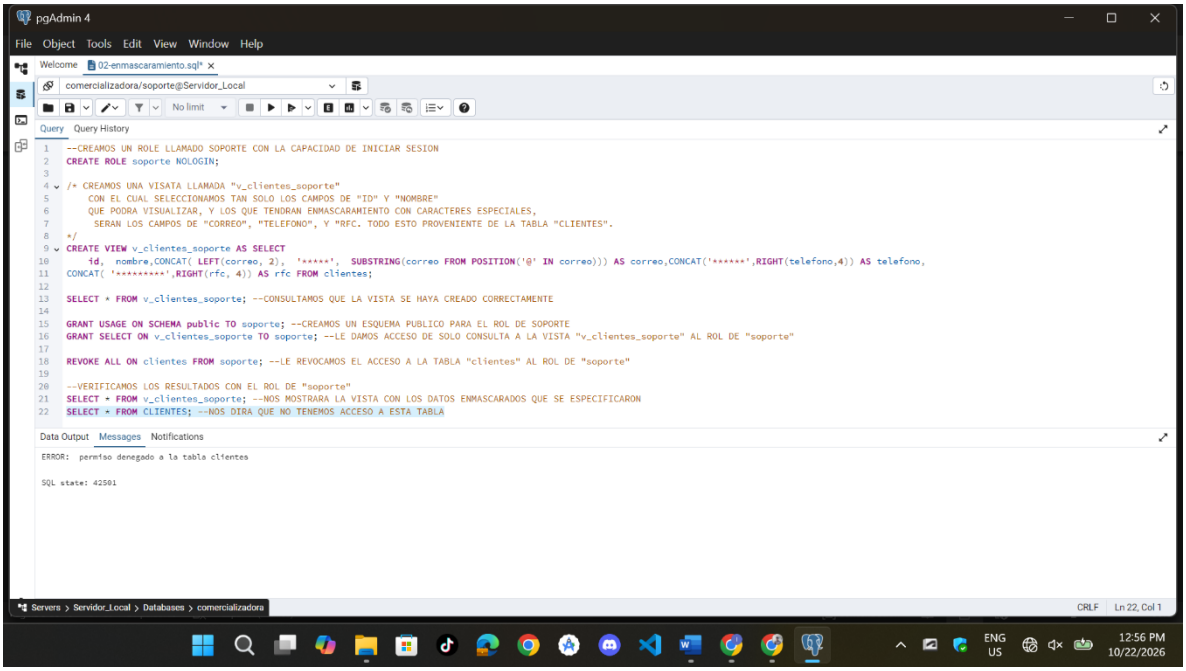
La consulta a la vista debe mostrar los datos protegidos:

SELECT * FROM v_clientes_soporte;



El acceso directo a la tabla debe estar restringido para el rol soporte:

SELECT * FROM clientes;



Preguntas

1. ¿Qué información continúa existiendo en la tabla original? Toda la infomacion, como el id del cliente, su nombre, su correo, su número de teléfono y rfc.
2. ¿Qué información puede visualizar el usuario soporte? Solo puede visualizar el id del cliente y su nombre. Los demás los puede ver, pero con un formato enmascarado.
3. ¿Por qué no es suficiente ocultar los datos únicamente en la aplicación? Porque podrían ver esos datos los que son del área de desarrollo, si estos están desarrollando un sistema para el área de soporte. Y además de que, si cualquier persona tiene acceso a la base de datos, podrían visualizarlos.
4. ¿Qué ocurriría si soporte tuviera acceso directo a clientes? Podría ver todos los datos de los clientes, como podrían ser: correo, rfc y número de teléfono.